2025 International Conference on Communication, Computing, Networking, and Control in Cyber-Physical Systems (CCNCPS) | 979-8-3315-9713-9/25/$31.00 ©2025 IEEE | DOI: 10.1109/CCNCPS66785.2025.11135791

Comprehensive Study of ICS Malware Attacks & Prioritizing Critical Defenses Using MITRE ATT&CK

Natalija Vlajic
EECS, Lassonde School of Engineering
York University
Toronto, Canada
vlajic@yorku.ca

Jazdeep Sarai
EECS, Lassonde School of Engineering
York University
Toronto, Canada
sarai24@my.yorku.ca

Goran Novkovic
Toronto Transit Commission (TTC)
Toronto, Canada
goran.novkovic@ttc.ca

***Abstract*—It is commonly acknowledged that attacks on Industrial Control Systems (ICS) can result in far greater negative impact on the target organizations as well as the general public relative to attacks on Enterprise IT systems. Among attacks on ICSs, those involving specialized malware are particularly concerning as they tend to be orchestrated by advanced nation-state actors, and are often aimed at producing tangible physical and/or operational damage. The goal of our research is to conduct a comparative analysis of all ICS malware strains known to-date, in the context of the MITRE ATT&CK framework. We generally distinguish between two main groups of ICS malware – those that aim to cause a significant operational impact (high-impact ICS malware) vs. those that only aim to halt the operation of the target system for purely financial reasons (ICS ransomware). For the purposes of our analysis, we propose and deploy a novel technique for prioritization/ranking of mitigation and detection strategies based on their overall effectiveness against a particular group/type of attacks. Our analysis shows that: a) each ICS malware group is associated with an entirely unique set of top-5 (i.e., top-4) adversary techniques, and b) when it comes to detection and mitigation of high-impact ICS malware strains, network-based defenses play an especially critical role, though their significance in dealing with ICS ransomware is also notable. These findings not only contribute to better general understanding of ICS malware strategies, but are also intended to guide the development of more cost-effective and better-tailored cyber-defenses in real-world ICSs.**

Keywords— ICS malware, MITRA ATT&CK framework, MITRE Navigator, security mitigation & detection

I. Introduction

The 2010 emergence of Stuxnet – the first computer malware specifically designed to target industrial control systems (ICSs) and result in physical damage or destruction – will be remembered as one of the most pivotal moments in the history of cyber security. With its exceptionally high levels of stealth and sophistication, and its ability to permeate from the Enterprise into the OT segment of the target organization until reaching and overtaking a particular type of critical PLCs, Stuxnet was effectively the first embodiment of an extremely dangerous cyberwarfare weapon [1]. In the years that followed, several other ICS malware strains have emerged, many of them designed to target a range of different industries/organizations via compromise of different system components. For the full list of ICS malware strains discovered to-date see Table I and Table II. In our study, we group all known ICS malware strains into two main categories: 1) those that aim to cause a significant operational disruption and/or physical damage – we refer to these as 'high-impact ICS malware', and 2) those that are financially motivated and operate as 'ICS ransomware'.

Building adequate protections against attacks involving ICS malware should be one of the most important priorities for all industrial and critical-infrastructure organizations. Ideally, these protections should be effective not only against the malware strains discovered to-date, but against new and emerging strains. As an important step towards achieving this objective, it is necessary to acquire a better understanding of the main similarities, as well as the key differences, between all currently known types of ICS malware – which will then allow us to identify a set of specific cybersecurity techniques with the greatest defensive potential. Namely, for either financial or operational reasons, deployment of too many cybersecurity protections is impractical or outright prohibitive for most real-world ICSs. Therefore, the imperative should be to prioritize the defences that offer the most comprehensive protection against the largest number of critical threats.

Our research seeks to answers the following questions: 1) Which adversary techniques are most commonly utilized by different ICS malware strains discovered to-date?, 2) How different are the adversary techniques deployed by high-impact ICS malware strains vs. those deployed by ICS ransomware strains?, 3) Which detection and mitigation techniques should an organization deploy in order to thwart the largest number of ICS malware strains, at once?

The reminder of this paper is organized as follows. In Section II, we provide a formal definition and brief survey of ICS malware. In Section III, we introduces the main general framework and tools deployed in this study. In Section IV, we present our novel methodology for ranking of mitigation and detection techniques based on their potential effectiveness in dealing with a particular type/group of attacks. In Section V, we present the main findings of our study, while in Section VI we close the paper with the summary of main findings and possible directions for future work.

II. ICS Malware: Main Categories & Strains

According to [2], ICS malware is defined as malicious software that satisfies the following three key properties:

a) **ICS-capable**, which means the software performs functions that can facilitate navigation, altering, or retrieval of information from OT networks and devices. In addition, the software can 'speak' ICS protocols and thus can interact with PLCs and other OT devices.

Authorized licensed use limited to: Universite De Sherbrooke. Downloaded on March 26,2026 at 16:36:53 UTC from IEEE Xplore. Restrictions apply.

b) **Designed with Malicious Intent**, which means that software originally developed for benign purpose but then retooled to achieve a nefarious objective should not be considered 'malware'.

c) **Result in Adverse Effects on OT Environment**, which can be any of the following: collecting sensitive process information, enabling unauthorized access to OT devices, downloading arbitrary logic and executable code to OT devices, manipulating PLC set points or other settings, etc.

Historically, attacks on industrial systems involving ICS malware have been able to achieve much greater disruption and overall impact on the target organizations relative to their malware-less counterparts ([3], [5]). This can be explained by the fact that ICS malware attacks are typically led by nation-state actors who have resources to develop highly sophisticated and specialized malware strains, and in many cases target one (or more) previously unknown and hard-to-discover zero-day vulnerabilities in OT devices or protocols.

TABLE I. HIGH-IMPACT ICS MALWARE STRAINS DISCOVERED TO-DATE

	Malware Name	Year Discovered	MITRE ATT&CK ID	Involved APT	Targeted Industries	Targeted ICS Components	Exploited ICS Communication Protocols	References
1	**Stuxnet**	2010	S0603	**Equation Group** (USA, Israel)	nuclear ICS	**Siemens PLCs**	**S7Comm Profibus**	**[3], [4], [5], [6]**
2	**Havex** (Backdoor.Oldrea)	2013	S0093	**Dragonfly / Energetic Bear** (Russia)	energy, aviation pharmaceutical, defense, petrochemical	**OPC Servers**	**OPC**	**[3], [4], [6]**
3	**BlackEnergy2**	2015	S0089	**Sandworm** (Russia)	ICS/SCADA companies, energy, railway, mining	**VPN end-points, HMIs, circuit breakers**	[HTTP, IP, TCP, ICMP, UDP, DNS]	**[3], [4], [5], [8]**
4	**Industroyer** (CrashOverride)	2016	S0604	**Sandworm** (Russia)	power grid	**Siemens SIPROTEC devices**	**IEC-101 IEC-104 IEC 61850 OPC**	**[3], [4], [6], [8]**
5	**Triton** (Trisis, HatMan)	2017	S1009	**TEMP.Veles** (Russia)	petrochemical	**Schneider Electric's Triconex Safety Instrumented System (SIS) controllers**	**TriStation**	**[3], [4], [5], [6]**
6	**Industroyer2**	2022	S1072	**Sandworm** (Russia)	power grid	**IEC-104 controllers**	**IEC-104**	**[3], [4]**
7	**Pipedream** (Incontroller)	2022	S1045	**Chernovite** (Russia)	ICS/SCADA systems	**Schneider Electric and Omron PLCs**	**OPC UA Modbus CODESYS**	**[7], [8]**
8	**Cosmicenergy**	2023	**NA**	Russia-linked red teaming group	power grid	**IEC-104 devices**	**IEC-104**	**[9], [10]**
9	**Fuxnet**	2024	S1157	**Blackjack group** (linked to Ukrainian intelligence services)	critical infrastructure including: airports, water treatment, gas-pipelines	**M-Bus industrial sensors**	**M-Bus**	**[11], [12], [13]**
10	**FrostyGoop** (Bustleberm)	2024	**NA**	Russia-linked APT	wide range of ICS & critical Infrastructure	**ENCO controllers / PLCs**	**Modbus TCP**	**[14], [15]**

TABLE II. ICS RANSOMWARE STRAINS DISCOVERED TO-DATE

	Malware Name	Year Discovered	MITRE ATT&CK ID	Involved APT	Targeted Industries	Targeted ICS Components	Exploited ICS Communication Protocols	References
1	**WannaCry**	2017	S0366	**APT38** (North Korea) suspected	many industries including healthcare, manufacturing, financial services, government	SMB service in production/OT systems	[SMB]	**[3], [17]**
2	**NotPetya** (ExPetr, GoldenEye, Petrwrap, Nyetya)	2017	S0368	**TeleBots Sandworm Team** (Russia)	many industries including pharmaceutical shipping, energy, gas&oil	SMB service in production/OT systems	[SMB, DHCP, NTLM]	**[3], [16]**
3	**BadRabbit** (EternalPetya, ExPetr)	2017	S0606	**TeleBots Sandworm Team** (Russia)	transportation, government services, media outlets	SMB service in production/OT systems	[SMB]	**[18], [19]**
4	**LockerGoga**	2019	S0372	**FIN6** (North Korea)	industrial and manufacturing firms	PCs and servers in production/OT systems		**[16], [20]**
5	**REvil** (Sodin, Sodinokibi)	2019	0496	**Gold Southfield** (Russia)	aluminum automotive, manufacturing, transportation, energy	encrypts files/data used by OT components	[SMB, HTTP]	**[16], [21]**
6	**EKANS**	2020	S0605	**Unkown** (potentially Iran and/or criminal non-nation state)	energy, healthcare, automotive, manufacturing	**various ICS-related processes** (e.g., GE Proficy data historian, Honeywell HMIWeb)		**[8], [22]**

Authorized licensed use limited to: Universite De Sherbrooke. Downloaded on March 26,2026 at 16:36:53 UTC from IEEE Xplore. Restrictions apply.

From 2010 to date, cybersecurity researchers have identified 10 main families of high-impact ICS malware strains [2], [14], [15] - with the full list of their names and main characteristics shown in Table I. As for different ICS ransomware strains, their precise number is not exactly known. However, for the purposes of this study we have relied on the publicly available information from the MITRE ATT&CK [3] repository, which identifies (only) 6 different ICS ransomware strains – as shown in Table II. We would like to emphasize that as per ICS malware definition form [2], our study focuses only on malware strains that specifically target and operate within ICS/OT environments. Ransomware strains that target industrial and critical infrastructure organizations, but do not spread to ICS/OT network segments are outside of our study's scope.

(Please note that due to the page limit of this publication, here we do not provide in-depth analysis of each individual ICS malware strain. Though, the interested reader is referred to the related literature and other resources enlisted in Table I and II.)

Before closing this section, we would like to point to two important observations pertaining to the two aforementioned groups of ICS malware:

1) The operation of modern-day industrial systems is heavily reliant on the use of specialized communication protocols, which can generally be grouped into three categories: Fieldbus, Industrial Ethernet, Service/System Oriented ([23], [24], [25]). (Examples of the most popular protocols in each category are shown in Figure 1.) As evident from Table I, to achieve its nefarious objective, every high-impact ICS malware strain either outright exploits the software modules implementing one (or more) of ICS protocols, or simply takes advantage of the protocol's normal/intended operation in the target system. This observation suggests that adequate network protections could play a critical role in thwarting attacks involving high-impact ICS malware. Our analysis presented in Section 5 will formally confirm the correctness of this hypothesis.

2) When it comes to ICS ransomware (see Table II), these malware strains tend NOT to utilize specialized ICS protocols, but rather make use of more general network protocols (e.g., SMB, NTLM), which get deployed across both IT and OT segments of a wide range of industrial systems. The choice of these more general protocols is likely due to a very different purpose behind the development and use of ICS ransomware, compared to high-impact ICS malware. Namely, ransomware groups are primarily motivated by quick financial gains, and often are not overcommitted to any particular target (i.e., a specific organization or a type of industrial system). Consequently, they opt to develop and deploy malware strains that are not overly specialized in terms of their operation and protocol use.

Fieldbus	Industrial Ethernet	Service/System Oriented
Profibus Modbus RTU CC-Link IEC 60870-5-101	Profinet EthernNet/IP EtherCAT Modbus TCP IEC 60870-5-104 DNP3	OPC MTConnect MQTT

Fig. 1. Examples of popular ICS communication protocols

III. MITRE ATT&CK Framework, Navigator Tool, and Top ATT&CK Techniques Calculator

MITRE ATT&CK [26] is the current state-of-the-art framework for modeling and analysis of adversary behaviors (i.e., modeling of cyber threats and attacks), and is based on the concepts of adversary tactics, techniques, and procedures (TTPs). The key building block of the framework are the so-called TTP matrices [27], which are visual sequential/hierarchical representations of adversary TTPs deployed in different operational environments (Enterprise, ICS, Mobile). The MITRE ATT&CK framework also comes with: 1) a repository of actual data pertaining to various real-world Advance Persistent Threat (APT) groups as well as the malware strains and malicious software tools used in their attack campaigns, 2) a number of open-source tools for modeling, analysis, or emulation of adversary behavior.

MITRE ATT&CK Navigator [28] is an open source tool built on the concept of MITRE ATT&CK matrices, and specifically designed to facilitate visualization and analysis of complex adversary behaviors. In particular, Navigator can be used to: 1) visually codify the tactics, techniques, and procedures (TTPs) deployed in the course of an actual attack or a potential threat, 2) compare and contrast TTPs deployed by (e.g.) different APTs or different malware strains, 3) help cyber defenders identify the best defences against each particular attack/threat, etc.

Top ATT&CK Techniques Calculator [29] is another MITRE tool that can be used to rank (prioritize) ATT&CK techniques in each given environment (i.e., organization), and thus help the organization focus its defence efforts on the techniques that are most likely to be deployed by potential adversaries. The calculator operates by taking into account - in the form of user input - the levels of the environment's security preparedness in the domains of network, process, file, cloud, and hardware monitoring. In addition, the calculator assigns each ATT&CK technique a score in three main categories (Actionability, Prevalence, Choke-Point), and then depending on the user input the three scores are weighed and combined to derive the technique's final ranking in that particular environment.

IV. Novel Methodology for Ranking/Prioritization of Mitigation and Detection Techniques

In this section, we briefly describe the methodology utilized in our study to find answers to the following Research Questions (RQs):

RQ1: Which adversary (i.e., ATT&CK) techniques are most commonly utilized by different ICS malware strains discovered to-date?

RQ2: How different are the adversary techniques deployed by high-impact ICS malware strains vs. those deployed by ICS ransomware strains?

RQ3: Which detection and mitigation techniques should an organization deploy in order to thwart the largest number of ICS malware strains, at once?

Authorized licensed use limited to: Universite De Sherbrooke. Downloaded on March 26,2026 at 16:36:53 UTC from IEEE Xplore. Restrictions apply.

The answers to RQ1 and RQ2 (which will be presented in the next section) are obtained by analyzing the TTP-matrix models of different ICS malware strains using the MITRE ATT&CK Navigator tool. As for RQ3, and in order to identify the detection and mitigation techniques with the highest defensive potential across two main groups of ICS malware, we needed to develop a novel scoring/ranking methodology. (According to our knowledge, the problem of identifying the most effective defences against a particular group of attacks, and specifically within the context of MITRE ATT&CK framework, has not been previously discussed in the literature.) Our novel methodology draws on the following:

- The MITRE Navigator model of an attack (including a malware-based attack) provides explicit information about the adversary techniques utilized by this attack.
- For each adversary technique, the MITRE ATT&CK repository offers an explicit list of mitigation and detection strategies that should be used against the given technique.
- Based on the above, and through an approach illustrated in Figure 2 and 3, it is possible to determine how effective each particular mitigation/detection strategy is against a group of attacks (i.e., it is possible to derive the effectiveness score of this mitigation/detection strategy against the given group). Clearly, the implementation of mitigation and detection strategies with the highest score should be prioritized over the implementation of other less effective defense strategies.

It should be noted from Figures 2 and 3 that, according to our methodology, the effectiveness score of a mitigation/detection strategy is reflective not just of the number of ATT&CK techniques that it can directly be used against, but also of the scale/degree at which it is able to (indirectly) fend off the specific attacks that are at the center of our interest/concern. It should also be noted that even though our methodology shares some common reasoning with the Top ATT&CK Techniques methodology, it is developed and used for an entirely different purpose. Namely, our methodology is focused on the ranking of mitigation/detection strategies depending on their effectiveness against a predefined set of attacks, while the Top ATT&CK Techniques methodology produces a non-specific ranking of adversary techniques in a particular environment and without considering any concrete type or category of attacks.

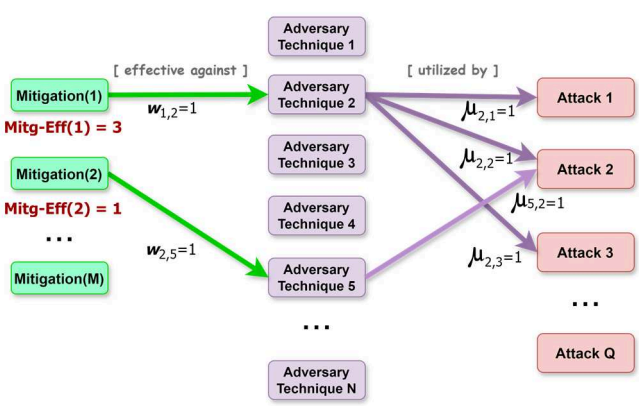

Fig. 2. Key concepts behind our novel approach for determining effectiveness of a mitigation (detection) strategy against a group of attacks

group of **attacks** of interest	**Atck** = {Atck(i): i=1, 2, ..., Q}
ATT&CK adversary ATT&CK techniques utilized by attacks in **Atck**	**Tech** = {Tech(j): j=1, 2, ..., N}
mitigation strategies recommended by MITRE ATT&CK framework against techniques from **Tech**	**Mitg** = {Mitg(k): k=1, 2, ..., M}
detection strategies recommended by MITRE ATT&CK framework against techniques from **Tech**	**Detc** = {Detc(l): l=1, 2, ..., P}

Given the above parameters, the **effectiveness of Mitg(k) against all attacks from Atck** – which we annotate as MitgEff(k) – can be calculated as:

$$\text{MitgEff(k)} = \sum_{j=1}^{N} w_{k,j} \cdot \sum_{i=1}^{Q} \mu_{j,i}$$

where

$$w_{k,j} = \begin{cases} 1, & \text{if Mitg(k) is effective against Tech(j)} \\ 0, & \text{otherwise} \end{cases}$$

$$\mu_{j,i} = \begin{cases} 1, & \text{if Tech(j) is utilized by Atck(i)} \\ 0, & \text{otherwise} \end{cases}$$

Similarly, the **effectiveness of Detc(l) against all attacks from Atck** – which we annotate as DetcEff(k) – can be calculated as:

$$\text{DetcEff(l)} = \sum_{j=1}^{N} \rho_{l,j} \cdot \sum_{i=1}^{Q} \mu_{j,i}$$

where

$$\rho_{l,j} = \begin{cases} 1, & \text{if Detc(l) is effective against Tech(j)} \\ 0, & \text{otherwise} \end{cases}$$

$$\mu_{j,i} = \begin{cases} 1, & \text{if Tech(j) is utilized by Atck(i)} \\ 0, & \text{otherwise} \end{cases}$$

Fig. 3. Parameters and formulas for calculation of 'mitigation/detection effectiveness score' against a specific group of attacks

V. Summary of Research Findings

A. *Most Prevalent Adversary Techniques in Two Groups of ICS Malware*

By deploying the MITRE Navigator as well as the information readily available from the MITRE ATT&CK's public repository, we were able to derive: 1) a combined Navigator matrix/layer of TTPs deployed by 10 high-impact ICS malware strains (see Appendix 1), and 2) a combined Navigator matrix/layer of TTPs deployed by 6 ICS ransomware strains (see Appendix 2).

As evident from the combined Navigator layer of 10 high-impact ICS malware strains (Appendix 1), these strains aggregately deploy a wide range of adversary techniques – with some being utilized by only one malware strain. However, it is also evident that five techniques emerge as 'quite common' for this category of malware, as they are utilized by 40% or more of strains – see Table III. From the perspective of ICS malware defences, prioritizing and investing into protection against these specific techniques will ensure a higher 'return on investment' (ROI) and/or greater risk reduction for the respective ICS organization.

Authorized licensed use limited to: Universite De Sherbrooke. Downloaded on March 26,2026 at 16:36:53 UTC from IEEE Xplore. Restrictions apply.

TABLE III. TOP 5 MITRE ATT&CK TECHNIQUES MOST COMMONLY DEPLOYED BY HIGH-IMPACT ICS MALWARE STRAINS

MITRE ATT&CK Technique	[%] of high-impact ICS malware strains deploying given technique
[T0855] Unauthorized Command Message	60% (6/10)
[T0888] Remote System Information Discovery	50% (5/10)
[T0846] Remote System Discovery	40% (4/10)
[T0869] Standard Application Layer Protocol	40% (4/10)
[T0809] Data Destruction	40% (4/10)

TABLE IV. TOP 4 MITRE ATT&CK TECHNIQUES MOST COMMONLY DEPLOYED BY ICS RANSOMWARE STRAINS

MITRE ATT&CK Technique	[%] of ICS ransomware strains deploying given technique
[T0828] Loss of Productivity and Revenue	83.3% (5/6)
[T0866] Exploitation of Remote Services	50% (3/6)
[T0822] External Remote Services	50% (3/6)
[T0867] Lateral Tool Transfer	50% (3/6)

The combined Navigator layer of 6 ICS ransomware strains from Appendix 2 reveals that this group of malware deploys a smaller and noticeably different set of adversary techniques. Nevertheless, even for this malware group, several techniques emerge as 'quite commonly utilized' - see Table IV. It should also be noted that for all but one strain of ICS ransomware *Loss of Productivity and Revenue* is the main impact category/technique – which is certainly in line with the general scope and purpose of ransomware software. On the other hand, the high-impact ICS malware strains (Table I and Appendix 1) are shown to be associated with (i.e., result in) a very diverse and much more concerning range/type of attack impacts, including *Loss of Safety* and *Manipulation of Control*.

B. *Critical Mitigation and Detection Strategies Against High-Impact ICS Malware*

Once the top-5 adversary techniques deployed by the 10 High-Impact ICS Malware strains got revealed (Table III), the next step in our analysis was to identify the most effective mitigation strategies against these five techniques, and ultimately against all malware strains from this particular group. To solve this problem using our methodology outlined in Section IV, the following steps were/are performed:

Step 1. Acquire explicit *Adversary Techniques to Attacks* mappings (i.e., determine $\mu_{j,i}$ values as per Figure 3) – which are visually depicted in Figure 4.

Step 2. Identify all mitigation strategies recommended by MITRE ATT&CK framework against the five adversary techniques from Table III. (For the full list of mitigation strategies identified at the end of this step see the left-hand side of Figure 5 or Table V.)

Step 3. Acquire explicit *Mitigations to Adversary Techniques* mappings (i.e., determine $w_{k,j}$ values as per Figure 3) – which are visually depicted in Figure 5.

Step 4: Calculate the final effectiveness score for all mitigation strategies identified in Step 2 by placing the acquired values of $\mu_{j,i}$ and $w_{k,j}$ into formula (1) of our methodology from Figure 3.

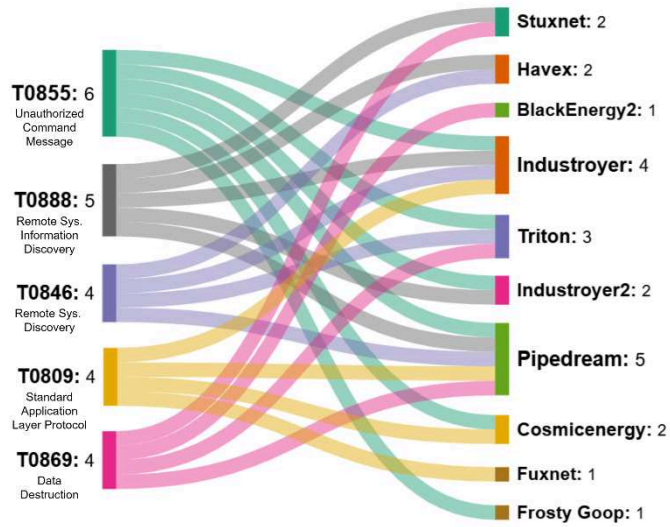

Fig. 4. **High-impact ICS malware**: prevalence of top-5 adversary techniques in different malware strains

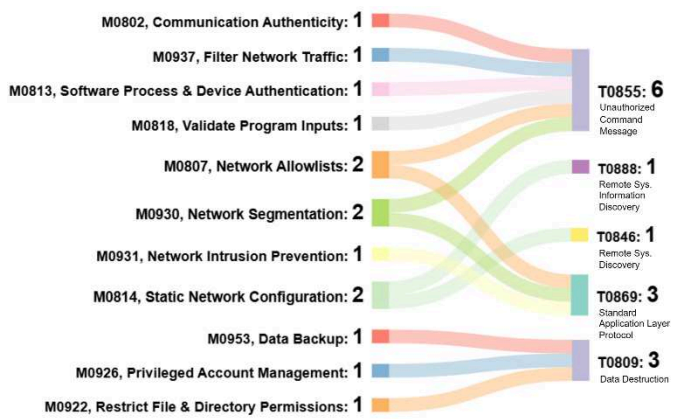

Fig. 5. **Mitigation** techniques mapped to top-5 adversary techniques in **high-impact ICS malware**

Table V shows the full list of identified mitigation strategies and their respective effectiveness scores against the high-impact ICS malware strains, placed in descending order. Clearly, the top scoring mitigation strategies in this list (*Network Allowlist*, *Network Segmentation*, *Static Network Configuration*) all pertain to network security. This confirms our earlier hypothesis that, in the defending of ICS systems against the high-impact ICS malware strains, network-related defences can play an especially important role, due to their ability to tightly control

Authorized licensed use limited to: Universite De Sherbrooke. Downloaded on March 26,2026 at 16:36:53 UTC from IEEE Xplore. Restrictions apply.

the way OT devices communicate and/or deploy specialized ICS communication protocols. Thus, the implementation of network-related defences from Table V should be prioritized in any real-world ICS environment potentially prone to or known to be targeted by this type of malware.

TABLE V. **MITIGATION** STRATEGIES AND THEIR EFFECTIVENESS SCORES AGAINST **HIGH-IMPACT ICS MALWARE**

MITRE ATT&CK Mitigation Technique	Effectiveness Score
M0807, Network Allowlists	10
M0930, Network Segmentation	10
M0814, Static Network Configuration	9
M0937, Filter Network Traffic	6
M0802, Communication Authenticity	6
M0813, Software Process & Device Authentication	6
M0818, Validate Program Inputs	6
M0931, Network Intrusion Prevention	4
M0953, Data Backup	4
M0926, Privileged Account Management	4
M0922, Restrict File and Directory Permissions	4

By performing a procedure similar to the one from the beginning of this section, but this time in Step 3 focusing on detection strategies and acquiring *Detection to Adversary Mappings* shown in Figure 6 (i.e., to determine $\rho_{k,j}$ values as per Figure 3), we were able to rank different detection strategies based on their potential effectiveness against the high-impact ICS malware. Table VI shows the full list of identified detection strategies and their respective effectiveness scores. Interestingly, the top detection strategy in this list (*Monitor Network Traffic*) again falls in the domain of network security, and has a score that considerably exceeds the scores of other identified strategies potentially capable of detecting high-impact ICS malware strains.

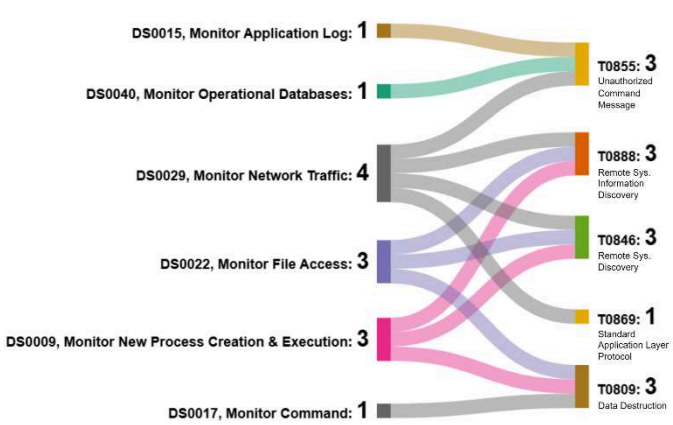

Fig. 6. **Detection** techniques mapped to top-5 adversary techniques in **high-impact ICS malware**

TABLE VI. **DETECTION** STRATEGIES AND THEIR EFFECTIVENESS SCORES AGAINST **HIGH-IMPACT ICS MALWARE**

MITRE ATT&CK Detection Technique	Effectiveness Score
DS0029, Monitor Network Traffic	19
DS0022, Monitor File Access	13
DS0009, Monitor New Process Creation & Execut.	13
DS0015, Monitor Application Log	6
DS0040, Monitor Operational Databases	6
DS0017, Monitor Command Execution	4

C. *Critical Mitigation and Detection Strategies Against ICS Ransomware*

By repeating a procedure similar to the one form the previous section, but this time focusing on the ICS ransomware strains from Table II, we were able to obtain the identities and effectiveness scores of MITRE ATT&CK strategies capable of mitigating and detecting this particular malware group – shown in Tables VII and VIII, respectively. It is evident from Table VII that, even in the case of ICS ransomware, two network related strategies (*Network Segmentation* and *Limit Access to Resources Over Network*) emerge as one of the most effective mitigation measures. Though, *Disable or Remove Feature or Program* and *Data Backup* turn out to have the same/similar mitigation potential against ICS ransomware, and ideally should also be implemented. (Note, *Data Backup* is a rather expected result here due to its well-known critical importance when dealing with ransomware attacks.) In the category of security detections (Table VIII), our methodology again identifies *Monitor Network Traffic* as the most effective strategy against ICS ransomware, similar to what was seen in Section B. This result just highlights the importance of having *Network Traffic Monitoring* adequately implemented and managed in any ICS/OT environment potentially targeted by either type of ICS malware.

TABLE VII. **MITIGATION** STRATEGIES AND THEIR EFFECTIVENESS SCORES AGAINST **ICS RANSOMWARE**

MITRE ATT&CK Mitigation Technique	Effectiveness Score
M0930, Network Segmentation	6
M0935, Limit Access to Resource Over Network	6
M0942, Disable or Remove Feature or Program	6
M0953, Data Backup	5
M0948, Application Isolation and Sandboxing	3
M0950, Exploit Protection	3
M0926, Privileged Account Management	3
M0919, Threat Intelligence Program	3
M0951, Update Software	3
M0916, Vulnerability Scanning	3
M0936, Account Use Policies	3
M0932, Multi-factor Authentication	3
M0927, Password Policies	3
M0918, User Account Management	3
M0931, Network Intrusion Prevention	3

Authorized licensed use limited to: Universite De Sherbrooke. Downloaded on March 26,2026 at 16:36:53 UTC from IEEE Xplore. Restrictions apply.

TABLE VIII. **DETECTION** STRATEGIES AND THEIR EFFECTIVENESS SCORES AGAINST **ICS RANSOMWARE**

MITRE ATT&CK Detection Technique	Effectiveness Score
DS0029, Monitor Network Traffic	9
DS0015, Monitor Application Log	6
DS0028, Monitor Logon Session	3
DS0017, Monitor Command Execution	3
DS0022, Monitor File Creation	3
DS0033, Monitor Network Share Access	3
DS0009, Monitor Process Creation	3

VI. CONCLUSIONS AND FUTURE DIRECTIONS

In this paper, we have presented the results of our study which has aimed to identify the most effective mitigation and detection strategies against two main groups of ICS malware, using MITRE ATT&CK framework. Our results clearly indicate that the deployment of strong network detection and mitigation techniques - specifically and adequately geared towards ICS protocols - is the key precondition for effective defending against ICS malware attacks. This observation is very much in line with a more general recommendation from [2], which states that the deployment of ICS protocol aware network monitoring is an invaluable tool against a wide range of cybersecurity incidents and compromises occurring in real-world ICS systems.

Another important contribution of this paper is the novel methodology for scoring/ranking (i.e., prioritization) of mitigation and detection strategies that are to be used against a particular group of attacks. According to our knowledge, this is the first methodology of its kind, as it conducts the ranking/prioritization of mitigation and detection techniques based on their effectiveness against a select/concrete set of attacks - rather than against all possible attacks affecting the target system. We are currently working on utilizing variations of this methodology (e.g.) by giving different weights/importance to different attacks depending on one or a combination of the following: a) attack's recency, b) attack's real-world prevalence, or c) actual likelihood that the attack strikes a specific organization (based on their threat intelligence insights). That way, mitigation and detection techniques with the potential to defend against more recent / more prevalent / more likely attacks would receive a higher score, and thus greater implementation priority.

REFERENCES

[1] Y. Mekdad et al. The Rise of ICS Malware: A Comparative Analysis. Proceedings of European Symposium on Research in Computer Security (ESORICS). Germany, October 2021. https://doi.org/10.1007/978-3-030-95484-0_

[2] Dragos. OT/ICS Cybersecurity Report: 8th Annual Year in Review. 2025.

[3] G. M. Makrakis et al. Industrial and Critical Infrastructure Security: Technical Analysis of Real-Life Security Incidents. IEEE Access, Vol. 9, 2021. https://doi.org/10.1109/access.2021.3133348

[4] T. Miller at al. Looking back to look forward: Lessons learnt from cyber-attacks on Industrial Control Systems. Elsevier Journal of Critical Infrastructure Protection, Vol. 35, 2021. https://doi.org/10.1016/j.ijcip.2021.100464

[5] R. Kumar at al. APT attacks on industrial control systems: A tale of three incidents. Elsevier Journal of Critical Infrastructure, Vol 37, 2022. https://doi.org/10.1016/j.ijcip.2022.100521

[6] M. Alanazi et al. SCADA vulnerabilities and attacks: A review of the state-of-the-art and open issues. Elsevier Journal of Computers & Security, 2023. https://doi.org/10.1016/j.cose.2022.103028

[7] Dragos Inc. Pipedream: Chernovite's Emerging Malware Targeting Industrial Control Systems. Whitepaper, 2022.

[8] M. Bhole et al. Enhancing Industrial Cybersecurity: Insights From Analyzing Threat Groups and Strategies in Operational Technology Environments. IEEE Open Journal of the Industrial Electronic Society, Vol 6, 2025. https://doi.org/10.1109/OJIES.2025.3527585

[9] Mandiant. COSMICENERGY: New OT Malware Possibly Related to Russian Emergency Response Exercises. Threat Intelligence Report. 2023.

[10] QuorumCyber. CosmicEnergy malware emerges. Threat Intelligence Report. 2023.

[11] B. Livingston et al. Strategic Overview of the Fuxnet Malware. Dragos Threat Intelligence Report, 2024.

[12] Claroty Team82. Unpacking the Blackjack Group's Fuxnet Malware. Threat Intelligence Report. 2024.

[13] txOne Networks. Strategies for Defense Against Fuxnet ICS Malware. Threat Intelligence Report. 2024

[14] Nozomi Networks Labs. OT: Protecting Against FrostyGoop/BUSTLEBERM Malware. Threat Intelligence Report. 2024.

[15] Palo Alto Unit42. FrostyGoop's Zoom-In: A Closer Look into the Malware Artifacts, Behaviors and Network Communications. Threat Intelligence Report. 2024.

[16] M. Benmalek. Ransomware on cyber-physical systems: Taxonomies, case studies, security gaps, and open challenges. Journal of Things and Cyber Physical Systems 4, 2024. https://doi.org/10.1016/j.iotcps.2023.12.001

[17] CheckPoint. WannaCry Ransomware Attack. Threat Intelligence Report. 2017.

[18] LogRhythms Labs. NotPetya Technical Analysis. Threat Intelligence Report. 2017.

[19] S. Sergei. "BadRabbit MS17-010 Exploitation Part One : Leak and Control. CrowdStrike Threat Intelligence Report. 2017.

[20] Dragos. Spyware Stealer Locker Wiper: LockerGoga Revisited. Threat Intelligence Report. 2020.

[21] Cybereason. REvil/Sodinokibi: The Crown Prince of Ransomware. Threat Intelligence Report. 2020.

[22] Dragos. EKANS Ransomware and ICS Operations. Threat Intelligence Report. 2020.

[23] M. Nankya et al. Securing Industrial Control Systems: Components, Cyber Threats, and Machine Learning-Driven Defense Strategies. MDPI Sensors Journal, 23(21), 8840, 2023. https://doi.org/10.3390/s23218840

[24] M. H. Collantes et al. Protocols and network security in ICS infrastructures. Spanish National Cybersecurity Institute (incibe), 2015.

[25] M. Jansson. Annual Analysis Reveals Steady Growth in Industrial Network Marke. HMS Technical News. 2024. https://www.hms-networks.com/news/news-details/17-06-2024-annual-analysis-reveals-steady-growth-in-industrial-network-market

[26] https://attack.mitre.org/

[27] M. Johnson. 2024. What is the MITRE ATT&CK Framework?.Balbix White Paper. https://www.balbix.com/insights/what-is-the-mitre-attck-framework/

[28] https://mitre-attack.github.io/attack-navigator/

[29] https://top-attack-techniques.mitre-engenuity.org/

Authorized licensed use limited to: Universite De Sherbrooke. Downloaded on March 26,2026 at 16:36:53 UTC from IEEE Xplore. Restrictions apply.

APPENDIX 1: MITRE ATT&CK NAVIGATOR COMBINED-LAYER OF 10 HIGH-IMPACT ICS MALWARE STRAINS

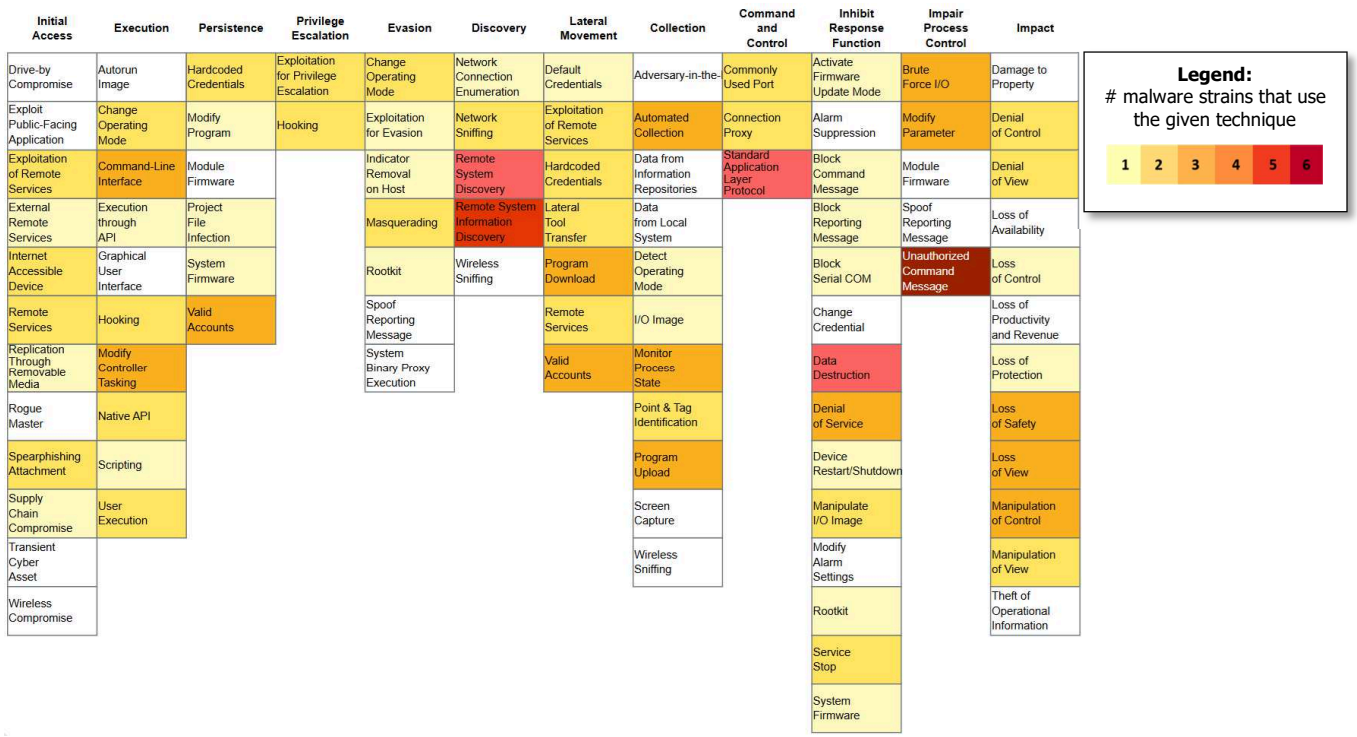

Fig. A.1 MITRE ATT&CK Navigator Layer produced combining Layers of 10 high-impact ICS malware strains from Table I

APPENDIX 2: MITRE ATT&CK NAVIGATOR COMBINED-LAYER OF 6 ICS RANSOMWARE STRAINS

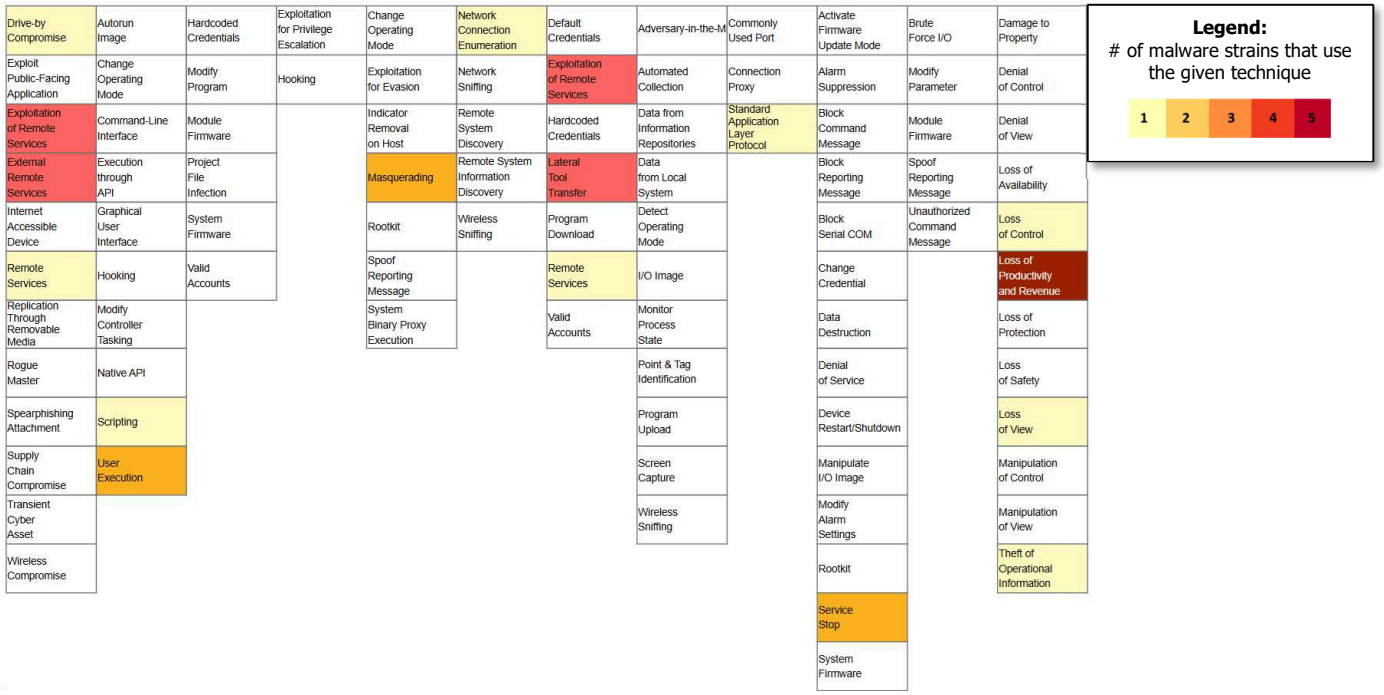

Fig. A.2 MITRE ATT&CK Navigator Layer produced combining Layers of 6 ICS ransomware strains from Table II

Authorized licensed use limited to: Universite De Sherbrooke. Downloaded on March 26,2026 at 16:36:53 UTC from IEEE Xplore. Restrictions apply.